

计算机安全与保密技术课程成绩评价表

课程名称	计算机安全与保密技术	课程编号	08A65002
论文题目	基于 Socket 的 Web 代理服务器设计与实现		
学生姓名		学号	
所在院系			

课程论文评阅记录

课程论文评价要素				
项目设计 35%	技术正确	内容完成	算法新颖	得分：
程序实现 35%	功能完成	运行稳定	设计合理	得分：
报告内容与格式 30%	报告清晰	见解独到	格式规范	得分：
报告值得肯定之处				
报告存在主要问题				
其他需要说明情况				

论文成绩：_____（百分制） 任课教师：_____

（课程论文占期末总评成绩的 60%）

评阅日期：_____

注：后接课程论文，格式参照课程论文模板或公开发表论文的风格。

基于 Socket 的 Web 代理服务器设计与实现

学生姓名 学号

(上海大学, 上海 200444)

摘要: 为实现课程要求的 Web 请求转发、指定域名拦截和网页关键词过滤, 本文设计并实现了一套基于 Python Socket 的正向代理服务器。系统采用多线程处理客户端连接, 通过解析 HTTP 代理请求建立上游连接, 并按照客户端地址、认证状态、访问频率、请求方法、域名和 URL 的顺序执行访问控制; 对于明文 HTTP 文本响应, 代理在返回客户端前检查正文关键词。系统同时提供 HTTPS CONNECT 隧道、GET 缓存、动态规则管理、管理前端和日志审计功能。测试采用批量自动验证与真实外网手工验收相结合的方法, Web/代理功能批次 15 项、规则与运行模式批次 7 项均通过, 真实 HTTP 网站的 URL 与正文过滤能够生成明确的 403 拦截页面。结果表明, 该系统完成了题目规定功能, 并具备规则热更新、运行统计和可追溯验收能力。

关键词: Web 代理; Socket; 访问控制; 关键词过滤; 日志审计; 动态规则

Design and Implementation of a Socket-Based Web Proxy Server

STUDENT NAME

Shanghai University, Shanghai 200444, China

Abstract: This project designs and implements a forward Web proxy server using Python sockets. The proxy parses HTTP proxy requests, establishes upstream connections, forwards responses, and applies access-control policies based on client IP addresses, authentication, request rate, HTTP methods, domains, and URL keywords. For plain HTTP text responses, the proxy examines response bodies and replaces blocked pages with an explicit HTTP 403 notice. The system also provides HTTPS CONNECT tunneling, GET caching, runtime rule management, an administration dashboard, and auditable logs. Automated batch tests and manual tests against real public HTTP websites were used for verification. All 15 Web/proxy tests and 7 rule/runtime-mode tests passed. The results show that the system satisfies the course requirements and provides practical rule updates, statistics, and traceable acceptance evidence.

Key words: Web proxy; Socket; access control; keyword filtering; audit log; dynamic rule

目录

1	课题背景与功能分析	3
1.1	开发目的	3
1.2	功能需求分析	3
1.3	开发环境与技术路线	3
2	系统总体设计	3
2.1	总体架构	3
2.2	模块组成	4
2.3	数据结构与配置模型	4
2.4	请求处理流程	4
3	核心功能原理、设计与实现	5
3.1	HTTP 正向代理与请求转发原理	5
3.2	访问控制策略链原理	5
3.3	网页正文关键词过滤原理	6
3.4	HTTPS CONNECT 隧道原理	6
3.5	缓存、认证与限流设计	6
3.6	动态规则管理与并发一致性	6
3.7	日志审计与管理前端设计	7
4	测试方案与验收结果	7
4.1	批量验证式测试	7
4.2	真实外网手工验收准备	8
4.3	真实网站域名拦截验收	8
4.4	真实网站 URL 关键词验收	9
4.5	真实网站正文关键词验收	9
4.6	手工验收日志与规则变更证据	10
5	项目开发总结	10
5.1	完成情况	10
5.2	存在问题与改进方向	10
6	心得体会	11
	参考文献	11
A	关键源代码（带注释）	11
A.1	域名匹配、客户端地址匹配与策略判定	11
A.2	HTTP 明文正文关键词过滤	12
A.3	HTTPS CONNECT 双向隧道	13
A.4	客户端连接的有序策略链	15
B	常用运行与验收命令	17

1 课题背景与功能分析

1.1 开发目的

Web 代理服务器位于客户端和目标 Web 服务器之间。客户端将访问请求发送给代理，代理解析请求中的目标地址，代替客户端连接目标服务器，再把响应转交给客户端。由于请求和响应均经过代理，代理能够在建立上游连接前判断目标是否允许访问，也能在收到明文响应后检查网页正文。该工作过程覆盖了 TCP 连接、HTTP 报文解析、访问控制、内容过滤和安全审计等网络安全基础知识。

本课题的开发目的包括三个方面。第一，完成题目规定的 HTTP 请求转发、指定域名拦截和网页关键词过滤功能。第二，通过 Socket 和 HTTP 协议解析理解正向代理的数据处理过程，并明确普通代理面对 HTTPS 加密流量时的可见性边界。第三，建立可管理、可验证和可审计的实验系统，使规则能够在运行期间修改，使每次放行与拦截都能够通过统计和日志进行说明。

1.2 功能需求分析

项目功能按照课程必做功能、系统管理功能和扩展访问控制功能进行划分。课程必做功能直接对应题目要求；系统管理功能用于解决规则如何修改、结果如何展示、行为如何追溯的问题；扩展访问控制功能用于体现代理服务器在实际网络安全场景中的使用方式。

功能类别	功能说明
代理转发	接收客户端 HTTP 请求，连接目标服务器，将请求和响应完整转发。
域名与 URL 控制	支持完整域名、父域名后缀、显式通配符和 URL 关键词拦截。
正文关键词过滤	检查明文 HTTP 文本响应，命中关键词时返回代理生成的 403 页面。
客户端访问控制	支持 IPv4、IPv6 和 CIDR 网段的客户端黑名单与白名单。
运行策略	支持请求方法过滤、HTTP Basic 代理认证、固定时间窗口限流和 GET 缓存。
规则管理	支持前端、JSON API 和命令行三种管理方式，规则增删改查后立即生效。
展示与审计	展示统计、排行、缓存状态和规则变更，支持结构化日志查询与 CSV 导出。

1.3 开发环境与技术路线

系统运行于 Windows 环境，使用 Visual Studio Code 进行开发，主要编程语言为 Python 3。代理服务使用 socket 建立 TCP 监听与上游连接，使用 threading 为每个客户端连接提供独立处理线程，HTTPS CONNECT 隧道使用 select 实现双向字节转发。管理后端使用 Python 标准库中的 ThreadingHTTPServer 提供页面和 JSON API，管理前端使用 HTML、CSS 与 JavaScript 实现。

配置和规则使用 JSON 文件保存，规则变更使用 JSONL 逐行记录，访问事件写入结构化文本日志。客户端 IP 和 CIDR 使用 ipaddress 模块校验，域名通配符使用 fnmatch 匹配。该技术路线不依赖大型第三方框架，便于在课程报告中说明协议处理和策略判定的底层过程。

2 系统总体设计

2.1 总体架构

系统由代理服务、管理后端、管理前端、配置与日志存储、测试工具五部分组成。代理服务监听 127.0.0.1:8080，处理浏览器或命令行客户端发来的代理请求；管理后端监听 127.0.0.1:8088，向前端和命令行工具提供管理 API。两个服务共享运行状态，规则修改后能够立即影响后续代理请求。

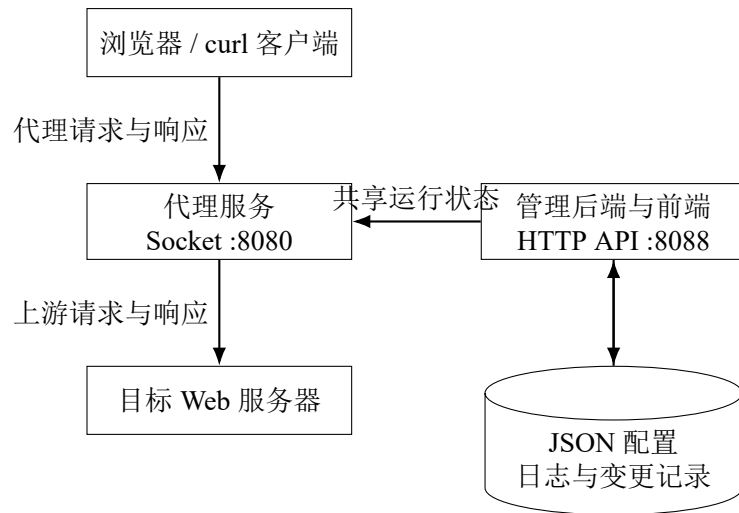


图 1 系统总体架构

2.2 模块组成

代理核心模块负责监听端口、解析 HTTP 请求、执行策略链、转发普通 HTTP 请求和建立 HTTPS CONNECT 隧道。规则配置模块负责读取配置文件、定义规则组、校验并标准化规则值。日志审计模块负责写入访问、拦截和错误事件，并提供查询、清空和 CSV 导出。证据模块负责读取批量测试生成的独立日志，在管理前端中重建最近验收统计。管理前端负责规则编辑、运行设置、统计、日志和规则变更展示。

2.3 数据结构与配置模型

运行状态对象保存当前配置、统计计数、访问排行、关键词命中排行、缓存、限流桶和规则变更历史。共享状态由线程锁保护，避免多个客户端线程和管理线程同时修改数据时产生不一致。

列表型规则包括域名黑名单、域名白名单、客户端 IP 黑名单、客户端 IP 白名单、URL 关键词、正文关键词和禁止方法。运行设置包括黑白名单模式、缓存开关与容量、代理认证、限流上限和时间窗口。规则变更后，系统同时更新内存配置和 JSON 文件，使修改立即生效并在重启后继续保留。

2.4 请求处理流程

请求进入代理后按照固定顺序处理。客户端 IP 规则最先执行，使无权使用代理的主机无法消耗认证和限流资源；认证通过后执行访问频率检查；随后检查请求方法、域名和 URL。前置策略通过后，GET 请求查询缓存，普通 HTTP 请求连接目标服务器并检查响应正文，CONNECT 请求建立加密字节隧道。最后更新统计并写入日志。

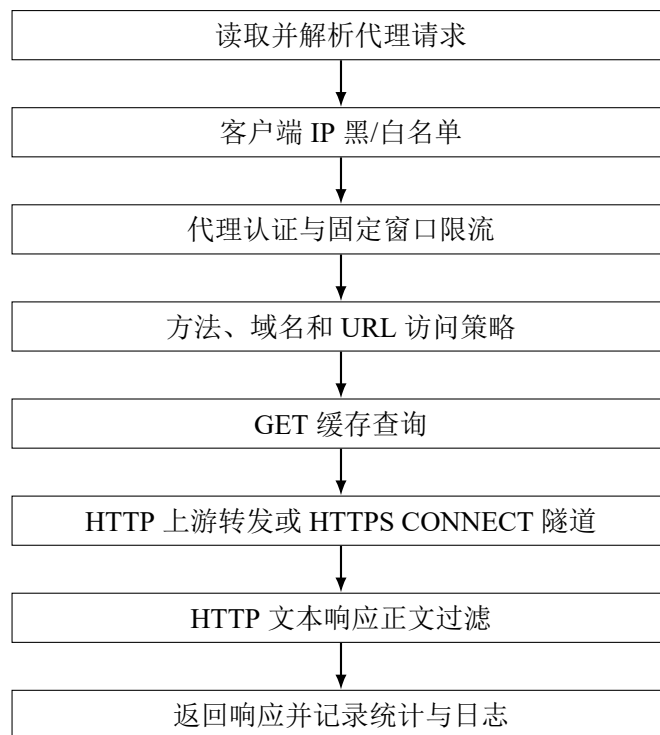


图 2 代理请求处理流程

3 核心功能原理、设计与实现

3.1 HTTP 正向代理与请求转发原理

HTTP 正向代理的核心作用是代替客户端访问目标服务器。客户端直连网站时，请求行通常只包含路径；客户端使用代理时，请求行可以携带完整 URL。代理首先从请求行和 Host 请求头中解析目标主机、端口与路径，再建立到目标服务器的 TCP 连接。由于目标服务器接收的是普通 HTTP 请求，代理需要将完整 URL 改写为路径形式，并重新生成 Host 请求头。

系统在转发前删除 Proxy-Authorization、Proxy-Connection 等只适用于代理连接的请求头，避免代理凭据泄露给目标网站。系统设置 Connection: close，以连接关闭作为本实验中响应读取结束的明确边界；同时设置 Accept-Encoding: identity，使服务器尽量返回未压缩正文，便于关键词检查。

上游连接由 TCP Socket 建立。代理发送改写后的请求后持续读取响应字节，直到目标服务器关闭连接。成功响应经过正文过滤后返回客户端；目标连接失败时返回 502，目标连接超时时返回 504。该设计将请求解析、上游连接和响应回传组成完整的 HTTP 代理链路。

3.2 访问控制策略链原理

访问控制采用有序、短路式策略链。每项策略返回“允许”或“拒绝”以及稳定的原因字段。只要某项策略拒绝请求，后续策略和上游连接立即停止，代理生成拦截响应并记录原因。该方式能够减少无效网络访问，也便于统计不同类型的拦截。

客户端访问控制根据 TCP 连接的源地址判断谁可以使用代理。IP 和 CIDR 网段通过网络前缀计算判断成员关系，黑名单优先于白名单；白名单为空时不限制客户端，白名单非空时只允许匹配项。代理认证检查 Proxy-Authorization 中的 Basic 凭据；固定时间窗口限流为每个客户端 IP 保存计数和重置时刻。

目标访问控制依次检查请求方法、白名单模式、域名黑名单和 URL 关键词。域名匹配支持完整域名、父域名后缀和显式通配符。URL 关键词检查目标主机、路径和查询参数。策略原因使用

`domain_blacklist`、`client_ip_blacklist`、`url_keyword`:... 等稳定字段，使前端、日志和测试能够使用相同语义。

3.3 网页正文关键词过滤原理

URL 过滤检查客户端发出的请求地址，正文过滤检查目标服务器返回的内容，两者位于处理流程的不同阶段。正文过滤首先分离 HTTP 响应头和响应体，再读取 `Content-Type` 与 `Content-Encoding`。系统只检查 HTML、纯文本、CSS、JavaScript 和 JSON 等文本类型；二进制文件和压缩响应直接放行，避免把任意字节错误解释为文本。

对于可检查的响应，系统将正文解码并统一转换为小写，然后与正文关键词规则逐项比较。命中关键词时，原始网页正文不会发送给客户端，代理改为生成 `403 Forbidden` 提示页。提示页包含拦截原因、命中规则、请求方法、目标地址和客户端地址，因此浏览器中显示的内容能够直接说明过滤结果。

正文过滤仅适用于代理能够读取的明文 HTTP 响应。若网站使用 HTTPS，浏览器和网站之间的应用层数据经过 TLS 加密，普通 CONNECT 代理无法读取网页正文。

3.4 HTTPS CONNECT 隧道原理

浏览器访问 HTTPS 网站时，先向代理发送 CONNECT 请求，请求中包含目标域名和 443 端口。代理可以在建立隧道前根据目标域名执行访问控制。目标允许访问时，代理连接目标服务器，向浏览器返回 `200 Connection Established`，随后只负责双向转发加密字节。

系统将客户端 Socket 和上游 Socket 设置为非阻塞状态，使用 `select` 监视两端是否存在可读数据。客户端数据到达时转发给网站，网站数据到达时转发给客户端，并在连接关闭或长时间无活动时结束隧道。

CONNECT 隧道没有解密 TLS。代理能够看到目标域名和端口，看不到 HTTPS 内部路径、查询参数和正文。因此 HTTPS 域名拦截能够生效，HTTPS URL 路径和正文关键词过滤需要额外实现中间人解密和证书信任管理，不属于本项目的实现范围。

3.5 缓存、认证与限流设计

HTTP GET 缓存以“目标主机、端口和路径”组成缓存键，每个条目保存响应字节、状态码、创建时间和过期时间。请求到达时先检查条目是否存在且未过期；命中时直接返回缓存响应，未命中时连接上游。缓存容量达到上限时删除最早创建的条目。该设计能够通过第一次请求未命中、第二次请求命中的现象展示代理缓存效果。

代理认证使用 HTTP Basic 机制。认证失败时返回 `407` 和 `Proxy-Authenticate` 响应头；认证成功后才进入限流和目标策略。转发请求时删除代理认证头，保证目标网站不会收到代理账号密码。

限流采用固定时间窗口算法。每个客户端 IP 对应一个计数桶，桶内保存当前请求数和窗口重置时间。窗口内计数达到上限后返回 `429`，并记录剩余等待时间。认证挑战不消耗已认证请求额度，修改限流参数时清空旧计数桶，便于运行期间重新配置。

3.6 动态规则管理与并发一致性

规则可以通过管理前端、JSON API 或命令行工具修改。三种入口最终调用同一组后端规则操作，包括新增、删除、修改、查询和整组替换。后端先校验规则组，再按规则类型标准化输入。例如请求方法统一为大写，IP/CIDR 由 `ipaddress` 校验并转换为标准网络地址。

规则修改在运行状态对象的线程锁内完成。后端先更新内存配置，再把完整配置写回当前 JSON 文件，同时追加一条 JSONL 变更记录。新的客户端请求会读取最新配置，因此规则不需要重启代理即可生效。锁保证多个代理线程和管理线程并发工作时不会同时破坏共享配置、统计或缓存数据。

3.7 日志审计与管理前端设计

日志按照用途分为访问日志、拦截日志、错误日志和规则变更记录。每条访问事件包含时间、事件类型、客户端地址、请求方法、目标主机、路径、状态码和字节数。拦截事件额外记录策略原因，规则变更记录包含操作类型、规则组、旧值、新值和保存结果。

日志查询模块把文本记录解析为结构化字段，支持按日志类别、事件类型和搜索关键词查询，并能够导出 CSV。运行状态对象维护总请求、放行、各类拦截、正文过滤、HTTPS 隧道、缓存、认证、限流和字节数统计。管理前端通过 JSON API 获取这些数据，提供规则编辑、统计展示、日志详情和规则变更回显。批量测试使用独立证据目录，前端可以读取最近一次验收结果，避免测试日志覆盖当前运行数据。

4 测试方案与验收结果

4.1 批量验证式测试

项目首先使用批量自动验证检查完整功能，再进行真实网站手工验收。自动测试为每个模块创建独立端口、测试配置和上游目标，并断言 HTTP 状态、响应内容、配置保存、统计和日志。测试分为 Web/代理功能批次与规则/运行模式批次，两个批次使用不同证据目录，能够重复运行并在管理前端中查看结果。

测试批次	覆盖内容	结果
Web/代理功能	HTTP 转发、域名拦截、URL 与方法过滤、正文过滤、CONNECT、缓存、前端、认证、限流、浏览器代理和验收证据	15/15
规则与运行模式	管理 API、白名单模式、规则增删改查、CLI、运行设置、客户端 IP/CIDR 与规则变更证据	7/7

批量验证命令如下：

```
python tests\run_all_smoke.py
```

测试通过时输出 all test batches passed。Web 验收证据保存在 tests/evidence/web，规则验收证据保存在 tests/evidence/rules。管理前端能够读取证据并重建总请求、总拦截、事件排行和规则变更回显。

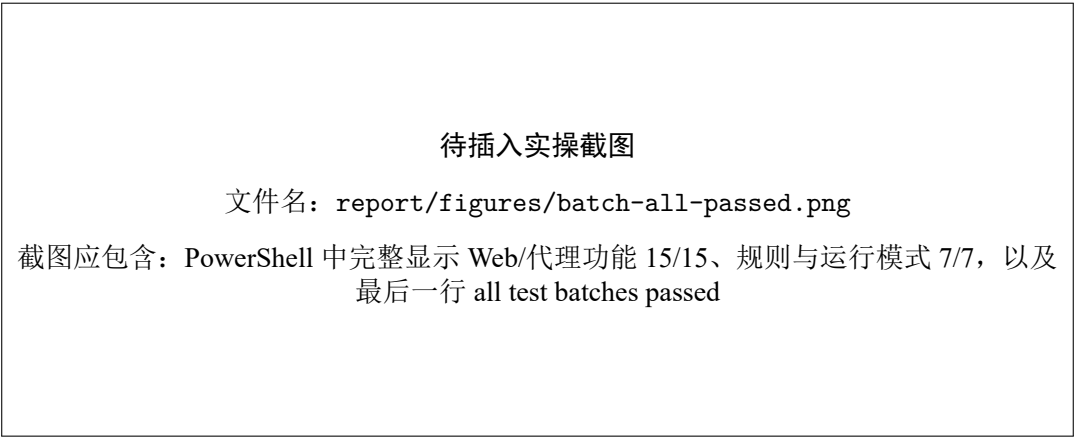


图 3 批量验证全部通过

待插入实操截图

文件名: report/figures/batch-dashboard.png

截图应包含: 管理首页选择“最近验收”后的总请求、总拦截、各类拦截统计、排行和最近日志

图 4 批量验证结果在管理前端中的展示

4.2 真实外网手工验收准备

手工验收使用真实外网地址。URL 关键词和正文关键词验收必须使用明文 HTTP 网站，因为普通 CONNECT 代理无法读取 HTTPS 路径和正文。验收前启动代理和专用浏览器：

```
python src\proxy.py --config config.example.json
powershell -ExecutionPolicy Bypass -File tools\start_proxy_browser.ps1
```

关闭认证和限流干扰，并切换为黑名单模式：

```
python tools\rule_cli.py set mode blacklist
python tools\rule_cli.py set proxy_auth_enabled false
python tools\rule_cli.py set rate_limit_enabled false
```

Edge 访问 HTTP 地址时需要输入完整的 http://。如果浏览器自动升级为 HTTPS，应关闭“自动切换到更安全的连接”，否则代理只能看到 CONNECT 域名。

4.3 真实网站域名拦截验收

添加 Bing 子域名黑名单并访问真实 HTTPS 网站：

```
python tools\rule_cli.py add blocked_domains *.bing.com
```

在专用 Edge 中访问 https://www.bing.com/。浏览器会向代理发送 CONNECT www.bing.com:443，域名命中后代理在建立 TLS 隧道前返回 403 页面。验收结束后删除规则：

```
python tools\rule_cli.py delete blocked_domains *.bing.com
```

待插入实操截图

文件名: report/figures/manual-domain-bing.png

截图应包含: Edge 地址栏中的 https://www.bing.com/，代理生成的 403 页面，以及展开后的 reason=domain_blacklist 和目标地址

图 5 真实网站域名拦截结果

4.4 真实网站 URL 关键词验收

URL 关键词验收使用真实明文 HTTP 地址 `http://httpforever.com/url-filter-demo`。该路径包含稳定关键词 `url-filter-demo`，代理在连接目标网站之前即可完成判断：

```
python tools\rule_cli.py delete blocked_domains httpforever.com
python tools\rule_cli.py add blocked_url_keywords url-filter-demo
```

在专用 Edge 中输入完整地址 `http://httpforever.com/url-filter-demo`。预期显示代理生成的 403 页面，详细信息中的拦截原因为 `url_keyword:url-filter-demo`。验收结束后删除规则：

```
python tools\rule_cli.py delete blocked_url_keywords url-filter-demo
```

待插入实操截图

文件名: `report/figures/manual-url-httpforever.png`

截图应包含: Edge 地址栏中的 `http://httpforever.com/url-filter-demo`，403 拦截页，以及展开后的 `url_keyword:url-filter-demo`

图 6 真实网站 URL 关键词拦截结果

4.5 真实网站正文关键词验收

正文关键词验收使用真实明文 HTTP 网站 `http://neverssl.com/`。该网站首页正文包含 `NeverSSL`，代理连接网站并收到响应后才能判断正文是否命中：

```
python tools\rule_cli.py delete blocked_domains neverssl.com
python tools\rule_cli.py delete blocked_url_keywords neverssl
python tools\rule_cli.py add blocked_content_keywords NeverSSL
```

在专用 Edge 中输入完整地址 `http://neverssl.com/`。预期原网页正文被代理生成的 403 页面替代，详细信息中的拦截原因为 `content_keyword:NeverSSL`。验收结束后删除规则：

```
python tools\rule_cli.py delete blocked_content_keywords NeverSSL
```

待插入实操截图

文件名: `report/figures/manual-content-neverssl.png`

截图应包含: Edge 地址栏中的 `http://neverssl.com/`，正文过滤后的 403 页面，以及展开后的 `content_keyword:NeverSSL`

图 7 真实网站正文关键词过滤结果

4.6 手工验收日志与规则变更证据

完成真实网站验收后，管理前端应显示域名拦截、URL 拦截和正文过滤统计。点击相应统计项进入日志详情页，可以按照原因查询具体事件。规则变更页面应显示上述规则的新增和删除记录。



图 8 真实网站拦截日志查询结果



图 9 真实网站验收规则变更记录

5 项目开发总结

5.1 完成情况

本项目完成了题目规定的 Web 请求转发、指定域名拦截和网页关键词过滤功能。代理能够解析 HTTP 代理请求并连接目标服务器，能够在连接目标服务器之前执行域名、URL、方法和客户端地址策略，也能够在收到明文 HTTP 响应后执行正文关键词过滤。

在基础功能之上，项目实现了 HTTPS CONNECT、GET 缓存、代理认证、访问频率限制、黑白名单模式、动态规则管理、管理前端、统计与日志审计。规则可以通过前端、API 和命令行修改，并立即作用于后续请求。自动测试与真实外网手工验收能够从响应、日志、统计和规则变更多个角度说明功能结果。

5.2 存在问题与改进方向

当前代理不解密 HTTPS 流量，因此无法检查 HTTPS 路径和正文。正文过滤主要面向 UTF-8、未压缩的文本响应，对其他字符编码、压缩响应、分块传输和大文件流式处理仍可继续完善。缓存和统计保存在进程内存中，重启后会清空；日志使用文件保存，在数据量较大时查询效率有限。

后续可以增加管理端登录、规则快照与回滚、SQLite 审计存储、定时规则和更完整的 HTTP 流

式处理。HTTPS 内容检查需要在受控实验环境中设计证书生成、客户端信任和私钥保护机制，并明确其安全与合规边界。

6 心得体会

本项目的主要收获是将 HTTP 协议、TCP Socket 和访问控制策略结合成一个可以实际运行的系统。实现代理转发后，可以直接观察浏览器请求经过代理、被改写、转发并返回的过程；实现域名与正文过滤后，可以区分“请求发送前拒绝”和“收到响应后过滤”两种处理位置。

开发过程中，浏览器对本机地址的代理绕过、HTTPS CONNECT 的加密边界、PowerShell 与 CMD 的 JSON 引号差异，以及限流对浏览器附加请求的影响，都说明网络程序的验证需要结合协议行为和运行环境。通过为每个模块设计独立测试、日志原因和恢复命令，项目最终形成了可重复验证的完整实验流程。

参考文献

- [1] FIELDING R, NOTTINGHAM M, RESCHKE J. HTTP Semantics: RFC 9110[S]. Internet Engineering Task Force, 2022.
- [2] THOMSON M, NOTTINGHAM M. HTTP/1.1: RFC 9112[S]. Internet Engineering Task Force, 2022.
- [3] RESCORLA E. The Transport Layer Security (TLS) Protocol Version 1.3: RFC 8446[S]. Internet Engineering Task Force, 2018.
- [4] RESCHKE J. The “Basic” HTTP Authentication Scheme: RFC 7617[S]. Internet Engineering Task Force, 2015.
- [5] Python Software Foundation. socket—Low-level networking interface[EB/OL]. <https://docs.python.org/3/library/socket.html>.
- [6] Python Software Foundation. ipaddress—IPv4/IPv6 manipulation library[EB/OL]. <https://docs.python.org/3/library/ipaddress.html>.

A 关键源代码（带注释）

正文重点说明功能原理与设计。本附录列出与核心原理对应的实际项目代码，代码中的注释用于说明关键判断和安全边界。

A.1 域名匹配、客户端地址匹配与策略判定

Listing 1 域名、客户端 IP/CIDR 与目标访问策略

```
1 def domain_matches(host, patterns):
2     """匹配域名规则，支持完整域名、后缀域名和显式通配符。"""
3     host = host.lower().strip(".")
4     for pattern in patterns:
5         pattern = pattern.lower().strip(".")
6         if not pattern:
7             continue
8         # 显式通配符由 * 表达，例如 *.baidu.com 或 *baidu*。
9         # 不再把普通 baidu 当成“任意包含 baidu”，避免误拦其他域名。
10        if fnmatch.fnmatch(host, pattern):
11            return True
12        if "*" not in pattern and (host == pattern or host.endswith("." + pattern)):
13            return True
14    return False
15
16
17 def client_ip_matches(client_ip, patterns):
18     """Match a client address against normalized single-IP and CIDR rules."""
19     try:
```

```

20     address = ipaddress.ip_address(client_ip)
21 except ValueError:
22     return False
23 for pattern in patterns:
24     try:
25         if address == ipaddress.ip_address(pattern):
26             return True
27         continue
28     except ValueError:
29         pass
30     try:
31         if address in ipaddress.ip_network(pattern, strict=False):
32             return True
33     except ValueError:
34         # A manually edited invalid configuration entry is ignored safely.
35         continue
36 return False
37
38
39 def check_client_access_policy(client_ip, config):
40     """Apply client allow/deny lists before authentication and target filtering."""
41     blocked_clients = config.get("blocked_client_ips", [])
42     if client_ip_matches(client_ip, blocked_clients):
43         return False, "client_ip_blacklist"
44
45     allowed_clients = config.get("allowed_client_ips", [])
46     if allowed_clients and not client_ip_matches(client_ip, allowed_clients):
47         return False, "client_ip_not_allowed"
48     return True, "allow"
49
50
51 def check_access_policy(request_info, config):
52     """执行访问控制：方法黑名单、白名单模式、域名黑名单和 URL 关键字拦截。"""
53     host = request_info["host"]
54     method = request_info["method"]
55     path = request_info["path"]
56     target = request_info["target"]
57     mode = config.get("mode", "blacklist").lower()
58
59     blocked_methods = [item.upper() for item in config.get("blocked_methods", [])]
60     if method in blocked_methods:
61         return False, "method_blacklist"
62
63     if mode == "whitelist":
64         allowed_domains = config.get("allowed_domains", [])
65         if not domain_matches(host, allowed_domains):
66             return False, "domain_not_in_whitelist"
67
68     blocked_domains = config.get("blocked_domains", [])
69     if domain_matches(host, blocked_domains):
70         return False, "domain_blacklist"
71
72     searchable_url = f"{host}{path} {target}".lower()
73     for keyword in config.get("blocked_url_keywords", []):
74         if keyword.lower() in searchable_url:
75             return False, f"url_keyword:{keyword}"
76
77     return True, "allow"

```

A.2 HTTP 明文正文关键词过滤

Listing 2 文本响应判断与正文关键词过滤

```

1 def is_text_content_type(content_type):
2     text_types = (
3         "text/html",
4         "text/plain",
5         "text/css",
6         "application/javascript",
7         "application/json",
8     )
9     content_type = content_type.lower()
10    return any(content_type.startswith(item) for item in text_types)
11
12
13 def response_header_value(header_lines, name):
14     return find_header(header_lines, name)
15
16
17 def parse_status_code(response_bytes):
18     first_line = response_bytes.split(b"\r\n", 1)[0].decode("iso-8859-1", errors="replace")
19     parts = first_line.split()
20     if len(parts) >= 2 and parts[1].isdigit():
21         return int(parts[1])
22     return 0
23
24
25 def filter_response_content(response_bytes, config, request_info=None, client_ip=""):
26     """对 HTTP 明文文本响应做正文关键字过滤，二进制或压缩内容直接放行。"""
27     if b"\r\n\r\n" not in response_bytes:
28         return response_bytes, None
29
30     header_bytes, body = response_bytes.split(b"\r\n\r\n", 1)
31     header_text = header_bytes.decode("iso-8859-1", errors="replace")
32     header_lines = header_text.splitlines()
33
34     content_type = response_header_value(header_lines, "Content-Type")
35     content_encoding = response_header_value(header_lines, "Content-Encoding")
36
37     if content_encoding and content_encoding.lower() not in ("identity", "none"):
38         return response_bytes, None
39
40     if not is_text_content_type(content_type):
41         return response_bytes, None
42
43     body_text = body.decode("utf-8", errors="replace")
44     body_text_lower = body_text.lower()
45
46     for keyword in config.get("blocked_content_keywords", []):
47         if keyword.lower() in body_text_lower:
48             return (
49                 build_policy_block_response(
50                     f"content_keyword:{keyword}",
51                     request_info,
52                     client_ip,
53                     detail=keyword,
54                 ),
55                 keyword,
56             )
57
58     return response_bytes, None

```

A.3 HTTPS CONNECT 双向隧道

Listing 3 HTTPS CONNECT 隧道转发

```
1 def forward_connect(client_socket, request_info, config):
2     """处理 HTTPS CONNECT: 建立 TCP 隧道, 只转发加密字节流, 不读取 HTTPS 正文."""
3     timeout = int(config.get("timeout_seconds", DEFAULT_TIMEOUT))
4     response = b"HTTP/1.1 200 Connection Established\r\nConnection: close\r\n\r\n"
5     bytes_to_client = 0
6     bytes_from_client = 0
7
8     try:
9         with socket.create_connection(
10             (request_info["host"], request_info["port"]),
11             timeout=timeout,
12         ) as upstream_socket:
13             client_socket.sendall(response)
14             bytes_to_client += len(response)
15
16             client_socket.setblocking(False)
17             upstream_socket.setblocking(False)
18
19             sockets = [client_socket, upstream_socket]
20             last_activity = time.time()
21
22             while True:
23                 if time.time() - last_activity > timeout:
24                     break
25
26                 readable, _, exceptional = select.select(sockets, [], sockets, 1)
27                 if exceptional:
28                     break
29
30                 for ready_socket in readable:
31                     try:
32                         data = ready_socket.recv(BUFFER_SIZE)
33                     except BlockingIOError:
34                         continue
35
36                     if not data:
37                         return {
38                             "outcome": "tunnel",
39                             "status_code": 200,
40                             "bytes_sent": bytes_to_client,
41                             "bytes_from_client": bytes_from_client,
42                         }
43
44                     last_activity = time.time()
45                     if ready_socket is client_socket:
46                         upstream_socket.sendall(data)
47                         bytes_from_client += len(data)
48                     else:
49                         client_socket.sendall(data)
50                         bytes_to_client += len(data)
51
52             return {
53                 "outcome": "tunnel",
54                 "status_code": 200,
55                 "bytes_sent": bytes_to_client,
56                 "bytes_from_client": bytes_from_client,
57             }
58     except socket.timeout:
59         bytes_sent = send_simple_response(
60             client_socket,
```

```

61         504,
62         "Gateway Timeout",
63         "target server timed out",
64     )
65     return {
66         "outcome": "error",
67         "status_code": 504,
68         "bytes_sent": bytes_sent,
69         "bytes_from_client": bytes_from_client,
70     }
71 except OSError as error:
72     bytes_sent = send_simple_response(
73         client_socket,
74         502,
75         "Bad Gateway",
76         f"cannot connect to target server: {error}",
77     )
78     return {
79         "outcome": "error",
80         "status_code": 502,
81         "bytes_sent": bytes_sent,
82         "bytes_from_client": bytes_from_client,
83     }

```

A.4 客户端连接的有序策略链

Listing 4 客户端访问控制、认证和限流处理顺序

```

1 def handle_client(client_socket, client_address, state):
2     """处理单个客户端连接，是认证、限流、规则过滤、缓存、转发的总入口。"""
3     config = state.get_config()
4     try:
5         data = client_socket.recv(BUFFER_SIZE)
6         if not data:
7             return
8
9         state.increment("total_requests")
10        state.increment("bytes_from_clients", len(data))
11
12        request_text = data.decode("iso-8859-1", errors="replace")
13        request_info = parse_http_request(request_text)
14        state.record_host(request_info["host"])
15
16        print("=" * 60, flush=True)
17        print(f"Client: {client_address[0]}:{client_address[1]}", flush=True)
18        print(
19            f"Request line: {request_info['method']} {request_info['target']} {request_info['version']}",
20            flush=True,
21        )
22        print(f"Host: {request_info['host_header']}", flush=True)
23        print(
24            "Parsed: "
25            f"method={request_info['method']} "
26            f"host={request_info['host']} "
27            f"port={request_info['port']} "
28            f"path={request_info['path']}",
29            flush=True,
30        )
31        print("=" * 60, flush=True)
32
33        # Client network policy runs before authentication and rate limiting so a
34        # denied machine cannot consume credentials or rate-limit capacity.

```

```

35     client_allowed, client_reason = check_client_access_policy(client_address[0], config)
36     if not client_allowed:
37         update_block_stats(state, client_reason)
38         bytes_sent = send_policy_block_response(
39             client_socket,
40             client_reason,
41             request_info,
42             client_address[0],
43         )
44         state.increment("bytes_to_clients", bytes_sent)
45         log_event(
46             state,
47             "BLOCK",
48             f"client={client_address[0]} method={request_info['method']} "
49             f"host={request_info['host']} path={request_info['path']} reason={client_reason}",
50         )
51         return
52
53     if not check_proxy_auth(request_info, config):
54         state.increment("auth_required")
55         bytes_sent = send_auth_required_response(client_socket)
56         state.increment("bytes_to_clients", bytes_sent)
57         log_event(
58             state,
59             "AUTH_REQUIRED",
60             f"client={client_address[0]} method={request_info['method']} host={request_info['host']}",
61         )
62         return
63
64     # Count authenticated proxy requests. This keeps a 407 authentication challenge
65     # from consuming the only permitted request when the limit is set to one.
66     rate_config_enabled = config.get("rate_limit_enabled", False)
67     if rate_config_enabled:
68         max_requests = int(config.get("rate_limit_per_minute", 60))
69         window_seconds = int(config.get("rate_limit_window_seconds", 60))
70         allowed_by_rate, retry_after, current_count = state.check_rate_limit(
71             client_address[0],
72             max_requests,
73             window_seconds,
74         )
75         if not allowed_by_rate:
76             state.increment("rate_limited")
77             bytes_sent = send_simple_response(
78                 client_socket,
79                 429,
80                 "Too Many Requests",
81                 f"rate limit exceeded, retry after {retry_after} seconds",
82             )
83             state.increment("bytes_to_clients", bytes_sent)
84             log_event(
85                 state,
86                 "RATE_LIMIT",
87                 f"client={client_address[0]} method={request_info['method']} "
88                 f"host={request_info['host']} count={current_count} "
89                 f"limit={max_requests} retry_after={retry_after}",
90             )
91             return
92     log_event(
93         state,
94         "RATE_ALLOW",
95         f"client={client_address[0]} method={request_info['method']} "
96         f"host={request_info['host']} count={current_count} limit={max_requests}",

```

B 常用运行与验收命令

命令	用途
<code>python src\proxy .py --config config.example.json</code>	启动代理服务和管理前端。
<code>python tests\run_all_smoke.py</code>	运行完整自动回归测试。
<code>python tools\rule_cli.py list</code>	查询所有规则组。
<code>python tools\rule_cli.py config</code>	查询当前运行配置。
<code>python tools\rule_cli.py changes --limit 20</code>	查询最近规则变更。
<code>python tools\rule_cli.py log-query --kind blocked --limit 20</code>	查询最近拦截日志。